CVERISKPILOT LLC — TECHNICAL WHITEPAPER SERIES

From Vulnerability Noise to Audit-Ready Decisions

Architecture, Proof of Concept, and Commercial Model for an AI-Powered Compliance Intelligence Platform

Document ID	CRP-WP-2026-002
Classification	Public
Version	1.0
Date	March 31, 2026
Author	CVERiskPilot Engineering
Supersedes	CRP-WP-2026-001

CVERiskPilot LLC | 100% Service-Disabled Veteran-Owned Small Business (SDVOSB)

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Texas, USA | https://cveriskpilot.com

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Table of Contents

1. Abstract
2. The Compliance Intelligence Gap
   - 1.1 Market Segmentation Failure
   - 1.2 Cost of the Status Quo
   - 1.3 Scale of the Problem
3. Platform Architecture
   - 2.1 Four-Layer Design
   - 2.2 CWE-to-Control Bridge Architecture
   - 2.3 Supported Frameworks
   - 2.4 Industry Presets
4. Intelligence Layer
   - 3.1 Multi-Source Enrichment Pipeline
   - 3.2 Risk Scoring Model
   - 3.3 AI-Powered Triage
   - 3.4 Agentic Tool-Calling Architecture
5. Ingestion and Processing
   - 4.1 Scanner Format Support
   - 4.2 Processing Pipeline
   - 4.3 Offline CLI Scanner
6. Multi-Tenant Architecture
   - 5.1 Three-Tier Tenant Hierarchy
   - 5.2 Deployment Model
   - 5.3 Data Isolation
7. Proof of Concept
   - 6.1 Test Configuration
   - 6.2 Results Summary
   - 6.3 Cross-Framework Compliance Impact
   - 6.4 Sample Finding Analysis

Copyright 2026 CVERiskPilot LLC. All rights reserved.

8. Security Architecture
    - 7.1 Authentication
    - 7.2 Authorization (RBAC + ABAC)
    - 7.3 Encryption and Key Management
    - 7.4 Audit Trail
9. Commercial Model
    - 8.1 Pricing Tiers
    - 8.2 Framework Gating
    - 8.3 Conversion Mechanism
10. Competitive Analysis
11. Market Opportunity
12. Technology Stack
13. Conclusion
14. References

Appendix A -- Full CLI Scan Output (Proof of Concept)
Appendix B -- CWE-to-Framework Mapping Reference

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Abstract

The vulnerability management and governance, risk, and compliance (GRC) markets operate as distinct silos. Vulnerability scanners produce findings with Common Weakness Enumeration (CWE) identifiers and CVSS scores. Compliance platforms track control checklists using framework-specific nomenclature. The mapping between them is performed manually by GRC analysts at an estimated cost of $3,600--$15,600 per audit quarter per product team. Only 18% of organizations systematically connect vulnerability risk to compliance posture.

This paper presents CVERiskPilot, an AI-powered compliance intelligence platform that bridges the gap between bottom-up vulnerability scanners and top-down compliance frameworks. The platform operates across four layers: (1) an ingestion layer supporting 11 scanner formats and 5 connector integrations; (2) an intelligence layer providing CVE enrichment (NVD, EPSS, CISA KEV), AI-powered triage, and automated cross-framework compliance mapping via a two-hop bridge architecture (CWE to NIST SP 800-53 to 12 additional regulatory frameworks); (3) a decision layer with risk acceptance workflows, POAM generation, and AI-generated audit-ready justifications; and (4) an action layer integrating with Jira, ServiceNow, and reporting pipelines.

We demonstrate the system through a live proof of concept -- scanning a production Node.js monorepo (140 API routes, 901 dependencies, 1,094 source files) and producing a 13-framework compliance impact assessment in 25.3 seconds.

Keywords: compliance intelligence, vulnerability management, NIST 800-53, CWE mapping, CMMC, HIPAA, PCI-DSS, ISO 27001, GDPR, FedRAMP, cross-framework mapping, GRC automation, AI triage, POAM generation

Copyright 2026 CVERiskPilot LLC. All rights reserved.

1. The Compliance Intelligence Gap

1.1 Market Segmentation Failure

The security tooling market is bifurcated into two categories that do not communicate:

Bottom-up tools (vulnerability scanners) detect security issues. Snyk finds vulnerable dependencies. SonarQube identifies code weaknesses. Nessus discovers infrastructure misconfigurations. Each produces findings with CWE identifiers, CVSS scores, and file locations. None of them can answer: *"Which HIPAA safeguards does this finding affect?"*

Top-down tools (GRC platforms) track compliance posture. Drata monitors SOC 2 controls. Vanta manages compliance evidence. Neither can parse a Nessus scan or calculate EPSS probability. They require manual data entry to populate control assessments.

Table 1: Market Segmentation and the Intelligence Gap

Capability	Bottom-Up (Scanners)	Top-Down (GRC)	CVERiskPilot
Vulnerability detection	Yes	No	Yes
CWE identification	Yes	No	Yes
CVSS/EPSS/KEV enrichment	Partial	No	Yes
Compliance control mapping	No	Manual	Automated
Multi-framework mapping	No	Manual	13 frameworks
POAM auto-generation	No	No	Yes
AI risk narratives	No	No	Yes
Audit-ready justifications	No	Partial	Yes

The bridge between these categories is a GRC analyst with a spreadsheet. CVERiskPilot replaces the spreadsheet.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

1.2 Cost of the Status Quo

Table 2: Estimated Manual Compliance Mapping Cost Per Audit Quarter

Activity	Hours	Frequency
Map findings to primary framework	8--16	Per scan cycle
Cross-reference additional frameworks	20--40	Per audit
Build/update Plan of Action & Milestones (POAM)	4--8	Per quarter
Prepare auditor evidence package	16--40	Per audit
AI/remediation narrative drafting	8--16	Per audit
Total per audit quarter	**56--120**	**Recurring**

At a loaded GRC analyst rate of $75--$150/hour [1], this translates to **$4,200--$18,000 per quarter** for a single product team. Organizations subject to multiple frameworks (e.g., HIPAA + PCI-DSS + SOC 2) multiply mapping effort by framework count. The industry-reported mean time to remediate (MTTR) stands at 74 days [2], with 45% of known vulnerabilities remaining unpatched beyond SLA windows -- not because teams lack tools, but because they lack the compliance context to prioritize correctly.

1.3 Scale of the Problem

The compliance mapping problem grows combinatorially. An organization with 500 CVE findings across 3 frameworks faces 1,500 mapping decisions. With 8,000 findings (a typical enterprise Nessus scan) across 5 frameworks, the decision space reaches 40,000 mappings per quarter. No analyst team scales to this.

Table 3: Compliance Mapping Scale by Organization Size

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Organization Profile	Findings/Quarter	Frameworks	Mapping Decisions
Startup (SOC 2 only)	200	1	200
Mid-market SaaS (SOC 2 + HIPAA)	2,000	2	4,000
Healthcare provider (HIPAA + PCI-DSS + SOC 2)	5,000	3	15,000
Defense contractor (CMMC + NIST 800-53 + FedRAMP)	8,000	3	24,000
MSSP managing 10 clients	50,000	5+	250,000+

2. Platform Architecture

2.1 Four-Layer Design

CVERiskPilot is organized into four functional layers, each addressing a distinct phase of the vulnerability-to-compliance lifecycle:

Figure 1: Platform Architecture -- Four-Layer Design

Copyright 2026 CVERiskPilot LLC. All rights reserved.

```
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 1: INGESTION                                                  │
│  11 scanner format parsers | 5 scanner connectors | CLI scanner      │
│  SBOM support (CycloneDX, SPDX) | Real-time push + scheduled pull│
│  Formats: Nessus, SARIF, CSV, JSON, CycloneDX, Qualys, OpenVAS,     │
│           SPDX, OSV, CSAF, XLSX                                      │
├──────────────────────────────────────────────────────────────────────┤
│  LAYER 2: INTELLIGENCE                                               │
│  NVD enrichment (CVSS v2/3.x/4.0) | Bulk EPSS scoring               │
│  CISA KEV cross-reference | Business impact scoring                  │
│  CWE → NIST 800-53 → 12-framework compliance mapping                 │
│  AI risk narratives | Agentic triage (7-tool loop)                   │
├──────────────────────────────────────────────────────────────────────┤
│  LAYER 3: DECISION                                                   │
│  Risk acceptance workflows | POAM generation & export                │
│  False positive justification with audit trail                       │
│  Compensating controls engine | "Not exploitable because..." logic│
│  Human-in-the-loop approval gates                                    │
├──────────────────────────────────────────────────────────────────────┤
│  LAYER 4: ACTION                                                     │
│  Jira bi-directional sync | ServiceNow integration                   │
│  Executive PDF/CSV reports | Scheduled delivery                      │
│  Webhook events (CloudEvents) | Evidence package export              │
│  SLA policies with breach detection and alerting                     │
└──────────────────────────────────────────────────────────────────────┘
```

2.2 CWE-to-Control Bridge Architecture

The compliance mapping engine uses a **two-hop bridge** with NIST SP 800-53 Rev 5 [3] as the canonical hub:

Figure 2: Two-Hop Cross-Framework Bridge

Copyright 2026 CVERiskPilot LLC. All rights reserved.

```
Vulnerability Finding
      │
      ▼
┌──────────────────┐
│      CWE ID      │   e.g., CWE-798 (Hard-Coded Credentials)
└──────────────────┘
         │  Hop 1: CWE → NIST 800-53 (42 controls mapped)
         ▼
┌──────────────────────────┐
│   NIST SP 800-53 Rev 5   │   Canonical hub
│   (most granular, most   │    CMMC derives from 800-171/800-53
│    cross-referenced)     │    FedRAMP = subset of 800-53
└──────────────────────────┘    CSF 2.0 officially maps to 800-53
         │  Hop 2: NIST 800-53 → 12 target frameworks
         ▼
┌──────────────────────────────────────────────────────────┐
│  CMMC Level 2        33 controls                         │
│  SOC 2 Type II        7 criteria                         │
│  FedRAMP Moderate    35 controls                         │
│  OWASP ASVS 4.0      7 categories                       │
│  NIST SSDF 1.1        8 practices                       │
│  GDPR                15 articles                         │
│  HIPAA Security Rule 19 safeguards                       │
│  PCI-DSS 4.0         20 requirements                     │
│  ISO/IEC 27001:2022  24 controls                         │
│  NIST CSF 2.0        31 subcategories                    │
│  EU CRA              15 requirements                     │
│  NIS2 Directive      12 measures                         │
└──────────────────────────────────────────────────────────┘
```

Why NIST 800-53 as hub. NIST SP 800-53 Rev 5 is the most granular and widely cross-referenced control catalog in the industry. CMMC Level 2 maps directly to NIST SP 800-171 [4], which derives from 800-53. FedRAMP baselines are defined subsets of 800-53. NIST publishes the official CSF-to-800-53 mapping [5]. ISO/IEC 27001:2022 Annex A controls have documented NIST equivalents [6]. Using 800-53 as the hub means adding a 14th framework requires one mapping table (O(n)), not 13 pairwise integrations (O(n^2)).

2.3 Supported Frameworks

Table 4: Compliance Frameworks Supported in v0.3.0

Copyright 2026 CVERiskPilot LLC. All rights reserved.

#	Framework	Version	Controls	Primary Market	Regulatory Driver
1	NIST SP 800-53	Rev 5	45	Federal, defense	FISMA, OMB A-130
2	CMMC	Level 2	33	Defense industrial base	DFARS 252.204-7012
3	SOC 2	Type II	7	SaaS, cloud	Customer trust
4	FedRAMP	Moderate	35	Federal cloud	FedRAMP authorization
5	OWASP ASVS	4.0	7	Application security	Industry standard
6	NIST SSDF	1.1	8	Secure SDLC	EO 14028, OMB M-22-18
7	GDPR	2016/679	15	EU data processing	EU regulation
8	HIPAA	Security Rule	19	Healthcare	45 CFR Part 164
9	PCI-DSS	4.0	20	Payment processing	Card brand mandate
10	ISO/IEC 27001	2022	24	International	Certification standard
11	NIST CSF	2.0	31	Cross-sector	Risk management
12	EU CRA	2024	15	EU product security	EU regulation
13	NIS2	Directive	12	EU essential entities	EU directive
	Total		**292+**		

2.4 Industry Presets

Table 5: Framework Presets for Common Compliance Profiles

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Preset	Frameworks	Target
`federal`	NIST 800-53, FedRAMP, SSDF	Federal agencies
`defense`	NIST 800-53, CMMC, SSDF	Defense industrial base
`enterprise`	NIST 800-53, SOC 2, ASVS, SSDF	SaaS / enterprise
`healthcare`	HIPAA, NIST 800-53	Healthcare orgs
`payments`	PCI-DSS, NIST 800-53, SOC 2	Payment processors
`international`	ISO 27001, GDPR, NIS2	EU / international
`eu-compliance`	GDPR, EU CRA, NIS2	EU digital products
`all`	All 13 frameworks	Full coverage

3. Intelligence Layer

The intelligence layer transforms raw vulnerability data into prioritized, compliance-contextualized, audit-ready output. This is the platform's primary differentiator.

3.1 Multi-Source Enrichment Pipeline

Every finding is enriched from three authoritative sources before any human interaction:

Table 6: Enrichment Data Sources

Source	Data Provided	Update Frequency	Cache TTL
NVD (NIST)	CVSS v2/3.x/4.0 vectors, CWE classification, CPE matching	Continuous	24h
EPSS (FIRST)	Exploitation probability (0--1 scale, 30-day window)	Daily	24h
CISA KEV	Known exploited status, due dates, remediation guidance	Daily	24h

Copyright 2026 CVERiskPilot LLC. All rights reserved.

The enrichment pipeline batches by unique CVE -- an 8,000-finding scan with 500 unique CVEs generates 500 enrichment lookups, not 8,000. Redis caching at 24-hour TTL means repeat scans of the same environment generate **zero external API calls**.

Table 7: Enrichment Processing Performance

Scenario	Parse	Enrich	Case Build	Total	AI (async)
Repeat scan (cached)	8--15s	~1s	10--20s	**~30s**	5--15 min
New scan (500 CVEs)	8--15s	~12s	10--20s	**~45s**	5--15 min
Large initial scan (2,000 CVEs)	8--15s	~45s	15--30s	**~90s**	10--20 min

3.2 Risk Scoring Model

CVERiskPilot computes a composite risk score that goes beyond raw CVSS:

```
Risk Score = f(CVSS_base, EPSS_probability, KEV_status, asset_context)

Where asset_context includes:
  - Environment (production vs staging vs development)
  - Internet exposure (public-facing vs internal)
  - Business criticality (critical, high, medium, low)
  - Data classification (confidential, internal, public)
```

This scoring model enables defensible prioritization. A CVSS 9.8 vulnerability on an air-gapped development server scores lower than a CVSS 7.5 vulnerability on an internet-facing production system processing cardholder data. The risk score breakdown is fully transparent -- every factor is visible in the finding detail, supporting auditor review.

3.3 AI-Powered Triage

The platform's triage engine classifies findings into three categories:

- **[TP] True Positive** -- Real issue requiring remediation
- **[REVIEW]** -- Likely real, requires human verification
- **[FP] False Positive** -- Auto-dismissed with machine-generated explanation

Auto-dismiss explanations are specific and auditable:

Copyright 2026 CVERiskPilot LLC. All rights reserved.

> *"Value contains Terraform variable interpolation* `${var.db_password}` *, not a hardcoded secret." "File is gitignored -- local-only development secret, not committed to version control."*

In the proof-of-concept scan (Section 6), **31% of findings were auto-dismissed** with explanations, directly reducing analyst workload without suppressing genuine issues.

3.4 Agentic Tool-Calling Architecture

For critical and high-severity findings, CVERiskPilot deploys a multi-tool AI triage agent that gathers evidence autonomously before generating risk assessments:

Table 8: Agentic Triage Tool Inventory

Tool	Function	Data Source
NVD Lookup	Retrieve full CVE record, CVSS vectors, CWE	NVD API
KEV Check	Determine active exploitation status	CISA KEV catalog
EPSS Query	Get exploitation probability	FIRST EPSS API
CVSS Decode	Parse and explain CVSS vector components	Local computation
Compliance Map	Map CWE to all 13 frameworks	Bridge table
Risk Score	Compute composite risk with asset context	Scoring engine
Audit Log	Record all tool calls for compliance trail	Immutable store

The agent operates in a tool-calling loop: it determines which tools to invoke based on the finding context, gathers data, and produces a structured risk assessment with source citations. Human-in-the-loop (HITL) approval gates ensure no AI-generated output reaches production without review.

Key output differentiator. Most tools produce vulnerability lists. CVERiskPilot produces audit-ready risk narratives:

> *"Although CVE-2023-XXXX is rated Critical (CVSS 9.8), exploitation requires authenticated access to an internal container isolated via network segmentation and RBAC, reducing practical risk. EPSS probability is 0.02 (2%),*

Copyright 2026 CVERiskPilot LLC. All rights reserved.

> *and the vulnerability is not listed in CISA KEV. Recommend: accept risk with 90-day re-evaluation. Compensating controls: network segmentation (AC-3), container isolation (SC-7), RBAC enforcement (AC-6)."*

That paragraph replaces hours of analyst research and is formatted for direct inclusion in audit evidence packages.

---

4. Ingestion and Processing

4.1 Scanner Format Support

CVERiskPilot normalizes findings from 11 scanner formats into a canonical schema, eliminating format-specific workflows:

Table 9: Supported Scanner Formats

Format	Scanner Examples	Detection Type
Nessus XML	Tenable Nessus, Tenable.io	Infrastructure VM
SARIF 2.1.0	GitHub CodeQL, Semgrep, ESLint Security	SAST
CycloneDX	Trivy, Grype, OWASP Dependency-Track	SBOM / SCA
SPDX	SPDX-compatible SBOM generators	SBOM
OSV	Google OSV, npm audit	Dependency
CSAF/VEX	Vendor security advisories	Advisory
Qualys XML	Qualys VMDR	Infrastructure VM
OpenVAS	Greenbone OpenVAS	Infrastructure VM
CSV	Universal export (any scanner)	Any
JSON	Custom / API export	Any
XLSX	Enterprise spreadsheet export	Any

Additionally, 5 native scanner connectors provide direct API integration with Tenable, Qualys, CrowdStrike, Rapid7, and Snyk for automated pull-based ingestion.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

4.2 Processing Pipeline

The ingestion pipeline processes scan data through four stages. Users see results progressively -- findings appear on the dashboard after Stage 3, without waiting for AI analysis:

Figure 3: Four-Stage Ingestion Pipeline

```
Stage 1: PARSE                    Stage 2: ENRICH
┌──────────────────────┐          ┌──────────────────────┐
│ Stream file from store │         │ Batch unique CVEs      │
│ Detect format (auto)   │──────►  │ NVD + EPSS + KEV       │
│ Parse in 500-finding   │         │ Redis cache (24h TTL)  │
│ chunks                 │         │ Cache hit: ~1s         │
│ 8K findings: ~10s      │         │ Cache miss: ~12s       │
└──────────────────────┘          └──────────────────────┘
                                              │
                                              │
Stage 4: AI ANALYSIS (async)      Stage 3: CASE BUILD
┌──────────────────────┐          ┌──────────────────────┐
│ Critical + High only   │         │ Dedup by CVE+asset     │
│ Batch 5 CVEs/call      │◄──────  │ Compute risk scores    │
│ Host info redacted     │         │ Apply SLA policies     │
│ Structured output      │         │ Refresh dashboard      │
│ Draft → approval gate  │         │ 8K findings: ~15s      │
│ 5-15 min (non-blocking)│         └──────────────────────┘
└──────────────────────┘
```

4.3 Offline CLI Scanner

The platform includes an open-source CLI scanner (`npx @cveriskpilot/scan`) that operates entirely offline:

- **Zero network calls** during scan execution
- **No data exfiltration** -- findings never leave the machine
- **Air-gapped compatible** -- operates in classified environments (SCIF, IL4+)
- **Four parallel scanners**: API security (AST-based), secrets detection (pattern + entropy), IaC policy evaluation, SBOM dependency analysis
- **Full compliance mapping** inline with scan results

This design is critical for defense contractors handling CUI/ITAR data, healthcare organizations processing PHI/ePHI, and any team whose codebase cannot be transmitted to external services.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

5. Multi-Tenant Architecture

5.1 Three-Tier Tenant Hierarchy

CVERiskPilot supports enterprise, MSSP, and consultancy deployment models through a three-tier tenant hierarchy:

Figure 4: Three-Tier Tenant Hierarchy

```
┌──────────────────────────────────────────────────────────────┐
│  PLATFORM (CVERiskPilot)                                     │
│  Cross-org analytics, billing, feature flags, global cache   │
│                                                              │
│  ┌──────────────────────────────────────────────────────┐   │
│  │  ORGANIZATION (customer / billing entity)            │   │
│  │  SSO boundary | Stripe subscription | SLA policies   │   │
│  │                                                      │   │
│  │  ┌────────────────┐   ┌────────────────┐            │   │
│  │  │  CLIENT A      │   │  CLIENT B      │   ...      │   │
│  │  │  Assets        │   │  Assets        │            │   │
│  │  │  Findings      │   │  Findings      │            │   │
│  │  │  Cases         │   │  Cases         │            │   │
│  │  │  Reports       │   │  Reports       │            │   │
│  │  └────────────────┘   └────────────────┘            │   │
│  └──────────────────────────────────────────────────────┘   │
└──────────────────────────────────────────────────────────────┘
```

Table 10: Deployment Scenarios by Tenant Model

Scenario	Hierarchy	Use Case
Enterprise	1 Org, Clients = business units	Single company, multiple teams
MSSP	1 Org, Clients = managed customers	Security provider managing 10+ clients
Consultancy	1 Org, Clients = engagements	Pen test / audit firm

MSSP analysts sign in once and pivot between client contexts without re-authentication -- the same workflow pattern used by CrowdStrike Flight Control and Tenable MSSP Portal.

5.2 Deployment Model

Table 11: Deployment Tiers

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Tier	Infrastructure	Isolation	Target
Pooled (default)	Shared database, prefix-isolated storage	Row-level	Free, Pro
Dedicated Stamp	Dedicated database, dedicated storage, dedicated KMS	Instance-level	Enterprise
MSSP Stamp	Shared database with schema-per-org, per-client SSO	Schema-level	MSSP
Self-hosted	Docker Compose + PostgreSQL	Full	Air-gapped

5.3 Data Isolation

Every database query is scoped by `organization_id` and `client_id`. A finding for Client A is never visible to Client B, even within the same organization. Enforcement occurs at the data access layer, not the UI layer, and is validated by automated isolation tests in CI/CD.

---

6. Proof of Concept

To validate the system, we executed CVERiskPilot against its own production codebase on March 31, 2026. This is a real-world monorepo -- not synthetic test data -- representative of a mid-size SaaS application.

6.1 Test Configuration

Table 12: Proof-of-Concept Parameters

Parameter	Value
Target	CVERiskPilot production monorepo
Codebase	25 packages, 140 API routes, 901 npm dependencies
Source files	1,094 (secrets scan), 22 IaC files, 29 policy rules
Frameworks	All 13 (`--preset all`)
Scanners	API security, secrets, IaC, SBOM
Runtime	Node.js 20 on Linux
Command	`npx @cveriskpilot/scan --preset all --verbose`

Copyright 2026 CVERiskPilot LLC. All rights reserved.

6.2 Results Summary

Table 13: Scan Results -- Severity Distribution and Triage Disposition

Severity	Count	Actionable	Review	Auto-Dismissed
Critical	10	0	8	2
High	47	42	5	0
Medium	30	8	0	22
Low	4	0	0	4
Total	**91**	**50**	**13**	**28 (31%)**

Execution time: 25.3 seconds. All four scanners ran in parallel. 28 of 91 findings (31%) were auto-dismissed with machine-generated explanations.

6.3 Cross-Framework Compliance Impact

Table 14: Controls Affected Per Framework

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Framework	Controls Affected	Example Control IDs
NIST SP 800-53	10	AC-3, SC-5, CM-7, IA-5, CM-6, SA-15, SC-28, SC-8, SI-11, AU-3
CMMC Level 2	9	AC.L2-3.1.2, SC.L2-3.13.1, CM.L2-3.4.2, IA.L2-3.5.3
SOC 2 Type II	4	CC6.1, CC6.8, CC8.1, CC7.2
FedRAMP Moderate	9	AC-3, SC-7, CM-6, IA-5, SA-11, SC-28, SC-8, SI-2, AU-3
OWASP ASVS 4.0	4	V1.2, V14.2, V1.1, V9.1
GDPR	3	Art.25, Art.30, Art.32
HIPAA Security Rule	7	164.312(a), 164.312(d), 164.312(e), 164.308(a)(1)
PCI-DSS 4.0	7	Req-7.2, Req-2.2, Req-8.3, Req-6.2, Req-3.5, Req-6.3
ISO/IEC 27001:2022	8	A.8.3, A.8.9, A.8.5, A.8.25, A.8.24, A.8.28
NIST CSF 2.0	2	PR.AA, PR.DS
EU CRA	2	CRA-3, CRA-4
NIS2 Directive	2	NIS2-21.2i, NIS2-21.2h
Total	**67**	**across 12 active frameworks**

6.4 Sample Finding Analysis

Figure 5: Cross-Framework Impact Tree for CWE-798 (Hard-Coded Credentials)

Copyright 2026 CVERiskPilot LLC. All rights reserved.

```
Finding:  Stripe Secret Key detected in .env.local:25
CWE:      CWE-798 (Use of Hard-Coded Credentials)
Scanner:  secrets
Triage:   [REVIEW] File is gitignored -- local-only secret

Compliance Impact (13 frameworks):
│
├── NIST 800-53:    IA-5, CM-6, SA-15, SC-28, SC-8
├── CMMC Level 2:   IA.L2-3.5.3, CM.L2-3.4.2, CA.L2-3.12.1,
│                   SC.L2-3.13.11, SC.L2-3.13.8
├── SOC 2:          CC6.1, CC8.1
├── FedRAMP:        IA-5, CM-6, SA-11, SC-28, SC-8
├── ASVS:           V1.2, V14.2, V1.1, V9.1
├── GDPR:           Art.25, Art.32
├── HIPAA:          164.312(a), 164.312(d), 164.312(e),
│                   164.308(a)(1), 164.308(a)(8)
├── PCI-DSS:        Req-2.2, Req-8.3, Req-6.2, Req-3.5
├── ISO 27001:      A.8.9, A.8.5, A.8.25, A.8.24
├── NIST CSF:       PR.DS
├── EU CRA:         CRA-4
└── NIS2:           NIS2-21.2h
```

One finding. Thirteen frameworks. Zero manual lookup. A GRC analyst seeing this output knows instantly that a hardcoded credential finding affects their HIPAA audit (5 safeguards), PCI-DSS assessment (4 requirements), and ISO 27001 certification (4 controls) -- without referencing a single mapping document.

---

7. Security Architecture

7.1 Authentication

Table 15: Authentication Methods

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Method	Provider	Use Case
Google OIDC	Google Identity Platform	Primary enterprise auth
SAML/OIDC Federation	WorkOS	Enterprise SSO (Okta, Azure AD)
GitHub OAuth	Direct	Developer onboarding
Email/Password	Custom (server-side sessions)	Fallback
Passkeys/WebAuthn	W3C standard	Passwordless
TOTP + Backup Codes	Standard MFA	Second factor
API Keys	`crp_*` prefixed, org-scoped	CI/CD automation

All sessions are server-side (Redis), replacing JWT-only approaches. Sessions support idle timeout, forced revocation, and concurrent session limits.

7.2 Authorization (RBAC + ABAC)

The platform implements 10 roles across three hierarchy levels with granular permission enforcement on all mutation API routes:

Table 16: RBAC Role Matrix

Level	Roles	Scope
Platform	Platform Admin, Platform Support	Cross-org
Organization	Org Owner, Security Admin, Analyst, Developer, Viewer, Service Account	Org-wide or client-scoped
Client	Client Admin, Client Viewer	Single client

RBAC is supplemented by attribute-based access control (ABAC) for contextual constraints: tenant scope enforcement, tier-based feature gating, data classification restrictions, and environment-based access limits.

7.3 Encryption and Key Management

- **At rest**: AES-256-GCM encryption via Google Cloud KMS with per-tenant key rings
- **In transit**: TLS 1.3 enforced; HSTS with preload

Copyright 2026 CVERiskPilot LLC. All rights reserved.

- **Customer-managed keys (BYOK)**: Enterprise tier supports customer-supplied keys via Cloud KMS External Key Manager
- **Secrets**: Centralized in Google Secret Manager with IAM-scoped access and automatic rotation

7.4 Audit Trail

Every security-relevant action is recorded in a tamper-resistant audit log with configurable retention (1--7 years). The agentic triage system logs every tool call, data source consulted, and decision point, producing a compliance-ready evidence chain for each risk assessment.

---

8. Commercial Model

8.1 Pricing Tiers

Table 17: Pricing and Entitlements by Tier

Tier	Price	Frameworks	Users	Assets	AI Calls/mo	Key Features
Free	$0	6 core	1	50	50	CLI, AI triage, dashboard
Founders Beta	$29/mo	10	5	250	250	API, Jira sync, webhooks
Pro	$149/mo	10	10	1,000	1,000	POAM export, scheduled reports
Enterprise	Custom	All 13+	Unlimited	Unlimited	Unlimited	SSO, custom parsers, dedicated infra
MSSP	Custom	All 13+	Unlimited	Unlimited	Unlimited	White-label, per-client billing

8.2 Framework Gating

The CLI scanner always runs all 13 frameworks. The monetization lever is **detail depth**, not scan access:

Copyright 2026 CVERiskPilot LLC. All rights reserved.

- **Free tier**: Full control detail for 6 core frameworks. Summary only (name + count) for 7 additional frameworks.
- **Paid tiers**: Full control IDs, descriptions, and remediation guidance for all entitled frameworks.

This design ensures the free tier delivers immediate value while clearly demonstrating what paid tiers unlock.

8.3 Conversion Mechanism

```
HIPAA Security Rule    7 controls affected  [PRO]
PCI-DSS                7 controls affected  [PRO]
ISO 27001:2022         8 controls affected  [PRO]

Unlock 7 frameworks with PRO → https://cveriskpilot.com/pricing
```

A healthcare organization seeing "HIPAA: 7 controls affected" can calculate immediate ROI: $149/month vs. 20+ hours of manual mapping per quarter ($1,500--$3,000 at analyst rates). **The platform pays for itself in the first week.**

---

9. Competitive Analysis

Table 18: Feature Comparison Matrix

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Capability	CVERiskPilot	Snyk	SonarQube	Wiz	Drata	Vanta
Vulnerability scanning	Yes	Yes	Yes	Yes	--	--
CWE identification	Yes	Yes	Yes	Partial	--	--
EPSS + KEV enrichment	Yes	Partial	--	Partial	--	--
NIST 800-53 mapping	45 controls	--	--	--	Manual	Manual
Multi-framework mapping	13 simultaneous	--	--	1--2	Manual	Manual
Cross-framework single scan	Yes	--	--	--	--	--
POAM auto-generation	Yes	--	--	--	--	--
AI risk narratives	Yes	Limited	--	Yes	--	--
Offline / air-gapped	Yes	--	Partial	--	--	--
Free CLI (permanent)	Yes	Limited	Community	--	--	--
SDVOSB set-aside eligible	Yes	--	--	--	--	--

Key differentiators:

1. **Only tool with 13-framework cross-mapping in a single scan.** All competitors require separate GRC integration or manual mapping.
2. **Offline-first architecture.** Air-gap ready for defense and classified environments.
3. **Bridge architecture scales linearly.** Framework 14 requires one mapping table, not 13 pairwise integrations.
4. **AI generates auditor-ready language**, not just severity scores.
5. **100% veteran-owned (SDVOSB)** -- eligible for government set-asides under FAR 19.1405.

---

10. Market Opportunity

Table 19: Total Addressable Market by Framework

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Framework	Target Market	US Entities	Compliance Driver	Timeline
CMMC Level 2	Defense contractors	80,000+	DFARS mandate [7]	Nov 2026 deadline
HIPAA	Healthcare	750,000+	HHS enforcement [8]	Ongoing
PCI-DSS 4.0	Payment processing	1,000,000+	Card brand mandate [9]	v4.0 enforced Mar 2025
SOC 2	SaaS / cloud	100,000+	Customer requirement	Ongoing
GDPR	EU data processors	500,000+	EU regulation [10]	Ongoing
ISO 27001	International companies	1,000,000+	Certification	Ongoing
FedRAMP	Federal cloud vendors	5,000+	Federal acquisition	Ongoing
NIS2	EU essential entities	160,000+	EU directive [11]	Ongoing

Revenue model. The CLI scanner serves as a zero-friction lead generation channel. Users discover compliance gaps at no cost; the natural upgrade path is driven by the gated framework detail they see but cannot access. Conservative projection: 2% conversion of CLI users who encounter a gated framework upsell yields 20 paid conversions per 1,000 scans.

11. Technology Stack

Table 20: Production Technology Stack

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Layer	Technology	Rationale
Runtime	Node.js 20, TypeScript 5.9	Type safety, ecosystem
Frontend	Next.js 15 (App Router), React 19, Tailwind CSS	SSR, performance
Database	PostgreSQL (Cloud SQL), Prisma ORM	ACID, JSON, FTS
Cache	Redis (Cloud Memorystore)	Sessions, enrichment, rate limiting
AI	Anthropic Claude API	Structured output, tool calling
Payments	Stripe	Checkout, subscriptions, webhooks
Auth	Google OIDC, WorkOS SSO, WebAuthn	Enterprise-grade
Compute	Google Cloud Run (containerized)	Autoscaling, pay-per-use
Storage	Google Cloud Storage	Immutable scan artifacts
Security	Cloud Armor WAF, Cloud KMS, Secret Manager	Defense-in-depth
CI/CD	Cloud Build, Terraform	Reproducible deployments
Observability	OpenTelemetry, Cloud Monitoring	SLO-driven operations

Current metrics: 76 pages, 140+ API routes, 205+ components, 25 packages, 1,171 tests, 13 compliance frameworks.

---

12. Conclusion

The compliance intelligence gap -- the manual, quarterly, per-framework mapping of vulnerabilities to regulatory controls -- costs organizations thousands of analyst hours and leaves 45% of known vulnerabilities unpatched beyond SLA windows. The gap exists because the security tooling market is bifurcated: scanners find problems, GRC platforms track controls, and nothing bridges them.

CVERiskPilot's two-hop bridge architecture (CWE to NIST 800-53 to 12 additional frameworks) automates this mapping entirely. The proof of concept demonstrates the system operating against a real production codebase: 91 findings mapped to 67 controls across 12 active frameworks in 25.3 seconds. The AI triage layer auto-dismissed 31% of findings with auditable explanations. The agentic tool-calling system produces risk narratives that replace hours of analyst research with auditor-ready language.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

For GRC teams, this means: **one scan replaces hundreds of hours of manual compliance mapping**. For the organizations they serve, it means faster audit readiness, lower compliance costs, and defensible prioritization backed by EPSS, KEV, and AI-generated risk context.

The platform is production-ready at v0.3.0-beta, with 13 frameworks, 11 scanner format parsers, 5 connector integrations, and a battle-tested multi-tenant architecture designed for enterprise and MSSP deployment.

---

13. References

[1] U.S. Bureau of Labor Statistics. "Information Security Analysts," Occupational Outlook Handbook, 2025. Median pay $120,360/year; loaded rate estimated at $75--$150/hour.

[2] Ponemon Institute. "The Cost of Vulnerability Management Gaps," 2024. Reports 74-day mean time to remediate and 45% unpatched rate beyond SLA windows.

[3] NIST. "Security and Privacy Controls for Information Systems and Organizations," SP 800-53 Rev 5, September 2020. https://doi.org/10.6028/NIST.SP.800-53r5

[4] NIST. "Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations," SP 800-171 Rev 2, February 2020. https://doi.org/10.6028/NIST.SP.800-171r2

[5] NIST. "The NIST Cybersecurity Framework (CSF) 2.0," February 2024. Includes informative reference mappings to SP 800-53. https://doi.org/10.6028/NIST.CSWP.29

[6] NIST. "SP 800-53 Comment Map to ISO/IEC 27001:2022." Cross-walk between NIST and ISO controls.

[7] U.S. Department of Defense. "Cybersecurity Maturity Model Certification (CMMC) Program," 32 CFR Part 170, Final Rule, October 2024. Certification required for new DoD contracts beginning November 2026.

[8] U.S. Department of Health and Human Services. "HIPAA Enforcement Highlights," Office for Civil Rights. Average resolution amount for data breach cases exceeds $2.5M.

[9] PCI Security Standards Council. "PCI DSS v4.0," March 2022. Full enforcement of all v4.0 requirements effective March 31, 2025.

[10] European Parliament. "General Data Protection Regulation (GDPR)," Regulation (EU) 2016/679, April 2016. Maximum administrative fines under Article 83: up to 4% of global annual turnover.

[11] European Parliament. "Directive (EU) 2022/2555 (NIS2)," December 2022. Penalties for essential entities under Article 34: up to EUR 10M or 2% of worldwide turnover.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Appendix A: Full CLI Output (Proof of Concept)

The following is the output from executing `npx @cveriskpilot/scan --preset all` against the CVERiskPilot production monorepo on 2026-03-31. Path names have been normalized for publication.

Copyright 2026 CVERiskPilot LLC. All rights reserved.

```
Preset "all": nist-800-53, soc2-type2, cmmc-level2, fedramp-moderate,
              owasp-asvs, nist-ssdf, gdpr, hipaa, pci-dss, iso-27001,
              nist-csf, eu-cra, nis2

Scanning: /home/user/cveriskpilot
Detected: Node.js, Docker
Frameworks: NIST 800-53 Rev 5, SOC 2 Type II, CMMC Level 2, FedRAMP Moderate,
            OWASP ASVS 4.0, NIST SSDF 1.1, EU GDPR, HIPAA Security Rule,
            PCI-DSS 4.0, ISO/IEC 27001:2022, NIST CSF 2.0, EU CRA, NIS2

Running dependency scanner...
Running secrets scanner...
Running IaC scanner...
Running API route security scanner...
  Scanned 140 API routes    | 49 security issues found
  Scanned 1094 files        | 39 secrets detected
  Scanned 22 IaC files      | 0 violations found
  Found 901 dependencies    | 3 vulnerable dependencies detected

CVERiskPilot Scan Results
2026-03-31  |  api-security, secrets, iac, sbom  |  25336ms

Summary
  10 critical  47 high  30 medium  4 low  0 info
  Total: 91 findings  |  50 actionable  |  13 review  |  28 auto-dismissed

Compliance Impact
----------------------------------------------------------------------
NIST 800-53           10 controls   AC-3, SC-5, CM-7, IA-5, CM-6,
                                    SA-15, SC-28, SC-8, SI-11, AU-3
CMMC Level 2           9 controls   AC.L2-3.1.2, SC.L2-3.13.1,
                                    CM.L2-3.4.2, IA.L2-3.5.3,
                                    CA.L2-3.12.1, SC.L2-3.13.11,
                                    SC.L2-3.13.8, SI.L2-3.14.1,
                                    AU.L2-3.3.1
SOC 2 Type II          4 controls   CC6.1, CC6.8, CC8.1, CC7.2
FedRAMP Moderate       9 controls   AC-3, SC-7, CM-6, IA-5, SA-11,
                                    SC-28, SC-8, SI-2, AU-3
OWASP ASVS             4 controls   V1.2, V14.2, V1.1, V9.1
GDPR                   3 controls   [PRO]
HIPAA Security Rule    7 controls   [PRO]
PCI-DSS                7 controls   [PRO]
ISO 27001:2022         8 controls   [PRO]
NIST CSF 2.0           2 controls   [PRO]
EU Cyber Resilience    2 controls   [PRO]
NIS2 Directive         2 controls   [PRO]

Unlock 7 frameworks with PRO --> https://cveriskpilot.com/pricing

Total: 67 controls affected across 12 frameworks
```

Copyright 2026 CVERiskPilot LLC. All rights reserved.

```
PASS  No findings at or above CRITICAL severity.
```

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Appendix B: CWE-to-Framework Mapping Reference

B.1 CWE-798: Use of Hard-Coded Credentials

Table B1: Cross-Framework Control Mapping for CWE-798

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Framework	Control ID	Control Description
NIST SP 800-53	IA-5	Authenticator Management
NIST SP 800-53	CM-6	Configuration Settings
NIST SP 800-53	SA-15	Development Process, Standards, and Tools
NIST SP 800-53	SC-28	Protection of Information at Rest
NIST SP 800-53	SC-8	Transmission Confidentiality and Integrity
CMMC Level 2	IA.L2-3.5.3	Authenticator Management
CMMC Level 2	CM.L2-3.4.2	Security Configuration Enforcement
SOC 2 Type II	CC6.1	Logical and Physical Access Controls
SOC 2 Type II	CC8.1	Change Management
FedRAMP Moderate	IA-5, CM-6, SA-11, SC-28, SC-8	Per NIST 800-53 baseline
OWASP ASVS 4.0	V1.2, V14.2, V1.1, V9.1	Auth, Dependency, Architecture, Communications
GDPR	Art.25, Art.32	Data Protection by Design; Security of Processing
HIPAA	164.312(a), (d), (e); 164.308(a)(1), (a)(8)	Access, Auth, Transmission, Management, Evaluation
PCI-DSS 4.0	Req-2.2, 8.3, 6.2, 3.5	Config, Auth, Development, Crypto Key Protection
ISO/IEC 27001	A.8.9, A.8.5, A.8.25, A.8.24	Config, Auth, SDLC, Cryptography
NIST CSF 2.0	PR.DS	Data Security
EU CRA	CRA-4	Vulnerability Handling
NIS2	NIS2-21.2h	Cryptography and Encryption Policies

B.2 CWE-862: Missing Authorization

Table B2: Cross-Framework Control Mapping for CWE-862

Copyright 2026 CVERiskPilot LLC. All rights reserved.

Framework	Control ID	Control Description
NIST SP 800-53	AC-3	Access Enforcement
NIST SP 800-53	AC-6	Least Privilege
CMMC Level 2	AC.L2-3.1.2	Transaction and Function Control
SOC 2 Type II	CC6.1	Logical and Physical Access Controls
FedRAMP Moderate	AC-3, AC-6	Access Enforcement, Least Privilege
OWASP ASVS 4.0	V1.2	Authentication Architecture
GDPR	Art.25	Data Protection by Design and by Default
HIPAA	164.312(a)	Access Control (Technical Safeguards)
PCI-DSS 4.0	Req-7.2	Restrict Access by Business Need-to-Know
ISO/IEC 27001	A.8.3	Information Access Restriction
NIST CSF 2.0	PR.AA	Identity Management and Access Control
EU CRA	CRA-3	Access Control Requirements
NIS2	NIS2-21.2i	Access Control Policies and Procedures

CVERiskPilot LLC | 100% Service-Disabled Veteran-Owned Small Business (SDVOSB) | Texas, USA

https://cveriskpilot.com | `npx @cveriskpilot/scan`

Document ID: CRP-WP-2026-002 | Classification: Public | Version 1.0

Copyright 2026 CVERiskPilot LLC. All rights reserved.